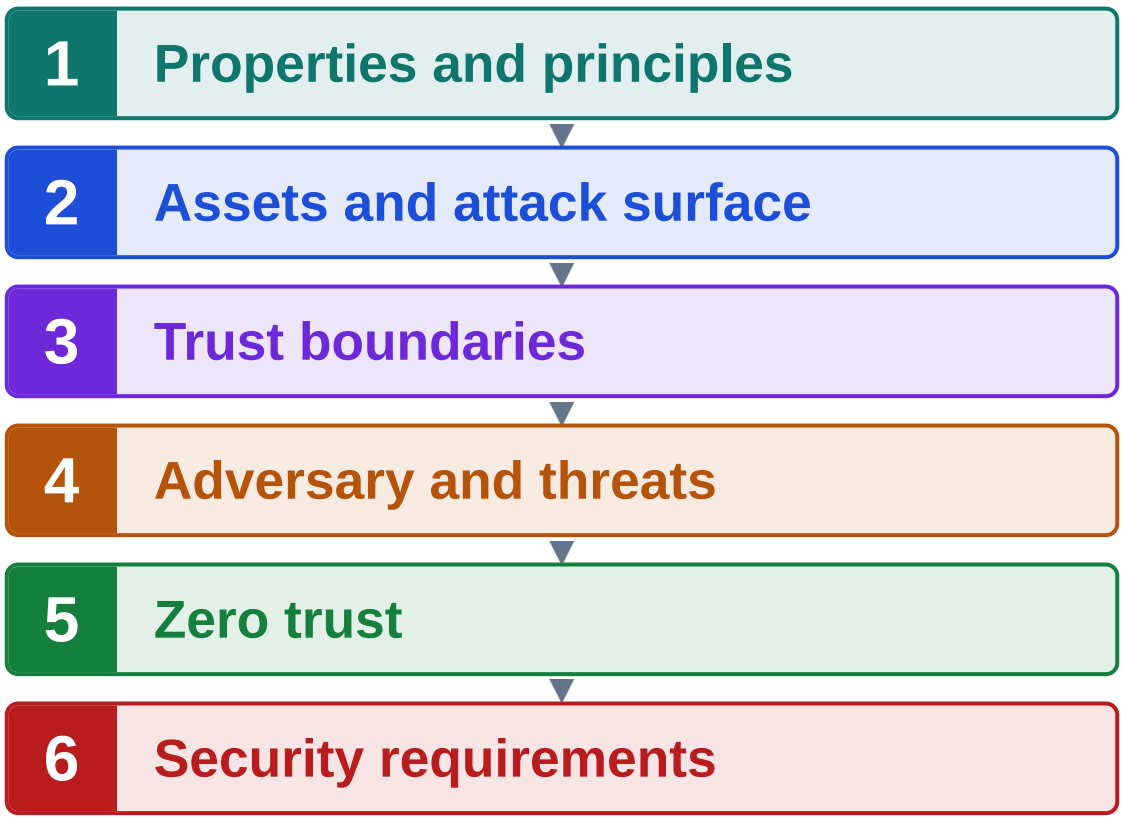
Lecture 1

Designing Secure Systems

Assets · trust boundaries · adversary · threats · requirements

Lecture outline



1

Properties and principles

what we protect and by which rules

Three security properties

Confidentiality

not disclosed to unauthorized parties

Integrity

information is accurate and complete

Availability

accessible on demand to an authorized party

Non-repudiation

an action cannot be denied later

Authenticity

a subject or resource is exactly what it claims to be

One vulnerability — several properties

Confidentiality	Integrity	Availability
data of many organizations was stolen	hidden accounts were added to the system	organizations took the service offline

Example: SQL injection in MOVEit Transfer, 2023

Eight design principles

Economy of mechanism

the mechanism is simple and small

Fail-safe defaults

deny unless explicitly allowed

Complete mediation

every access is checked

Open design

only the key is secret

Separation of privilege

critical actions need several parties

Least privilege

only the rights that are needed

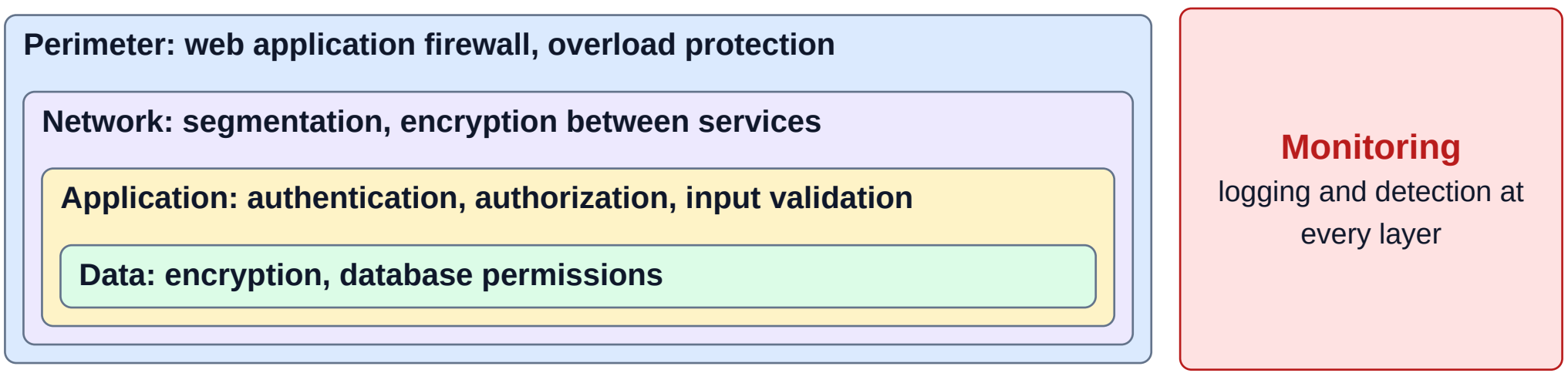
Least common mechanism

minimum of shared facilities

Psychological acceptability

protection is easy to use

Defense in depth



Failure of one layer does not lead to a full compromise

Principles are violated in real incidents

Incident	Violated principle	What happened
Capital One, 2019	Least privilege	A role with excessive storage access: data of about 100 million people was copied
SolarWinds, 2020	Separation of privilege	A backdoor in the build environment: about 18,000 organizations received the update
Log4Shell, 2021	Economy of mechanism	A logging library performed lookups in external directories from within a string

2

Assets and attack surface

what we protect and where it can be attacked

Assets of the training web shop

Customer data

key property: confidentiality

Payment transactions

key: integrity and confidentiality

Payment service key

key property: confidentiality

Catalog and prices

key property: integrity

Website operation

key property: availability

Attack surface: two adversaries

External adversary

Entry points
internet-facing services, e-mail, third-party libraries, employees

Means of intrusion
vulnerability in a public service, password guessing, injections, phishing, backdoor in a dependency

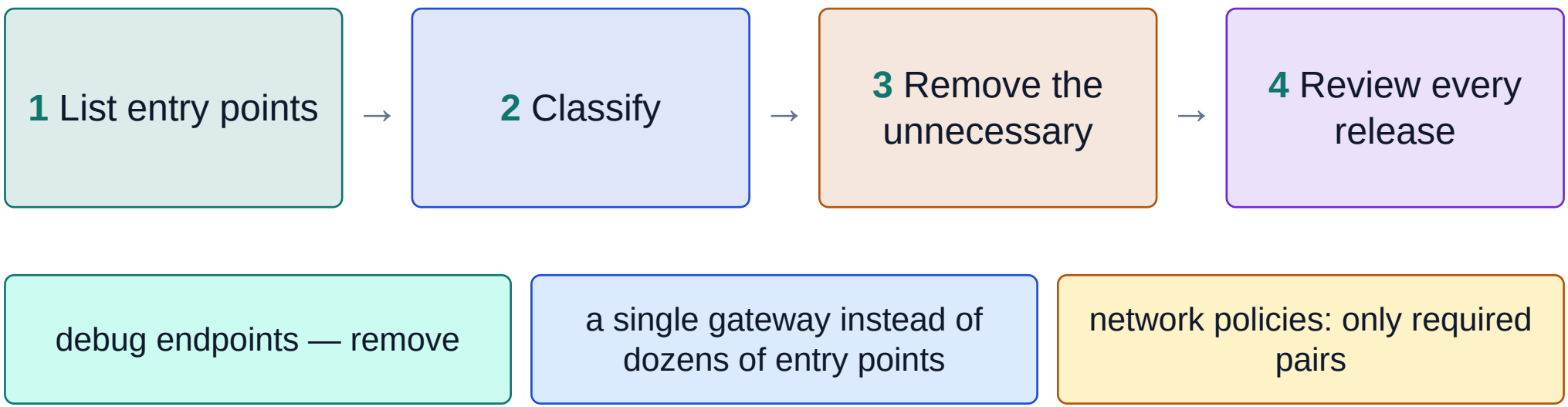
Insider

Entry points
workstations, admin panels, databases, removable media

Means of intrusion
abuse of rights, privilege escalation, data exfiltration, physical access

> An outsider looks for an entry point, an insider goes beyond the rights granted

Reducing the attack surface



3

Trust boundaries

where the level of trust changes

Typical trust boundaries

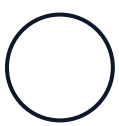
Client → server	TLS encryption, token and input validation
Service → service	mutual authentication, rights, request checks
External system → ours	key or OAuth, rate limiting
Build → production	artifact signing, admission policies
User → administrator	second factor, full audit
Cloud → on-premises	VPN or identity-aware access

Data flow diagram elements



External entity

a user or an external system



Process

a component that processes data

Data store

database, files, cache

Data flow

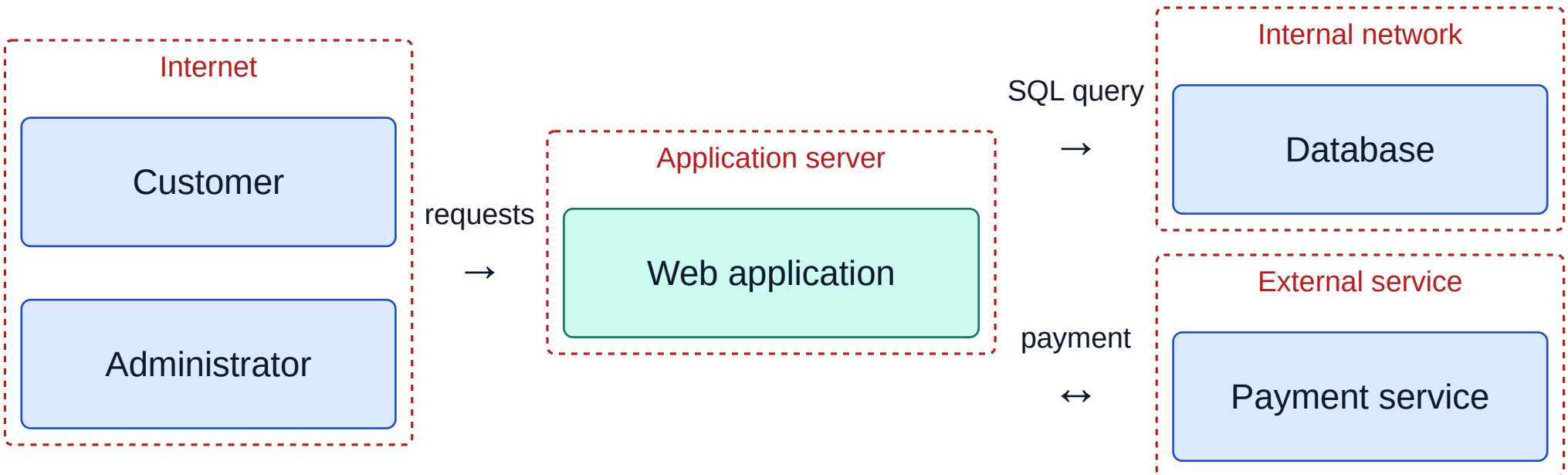
data transfer between elements



Trust boundary

where the level of trust changes

Data flow diagram of the web shop



Three trust boundaries and four flows — this is where we look for threats

4

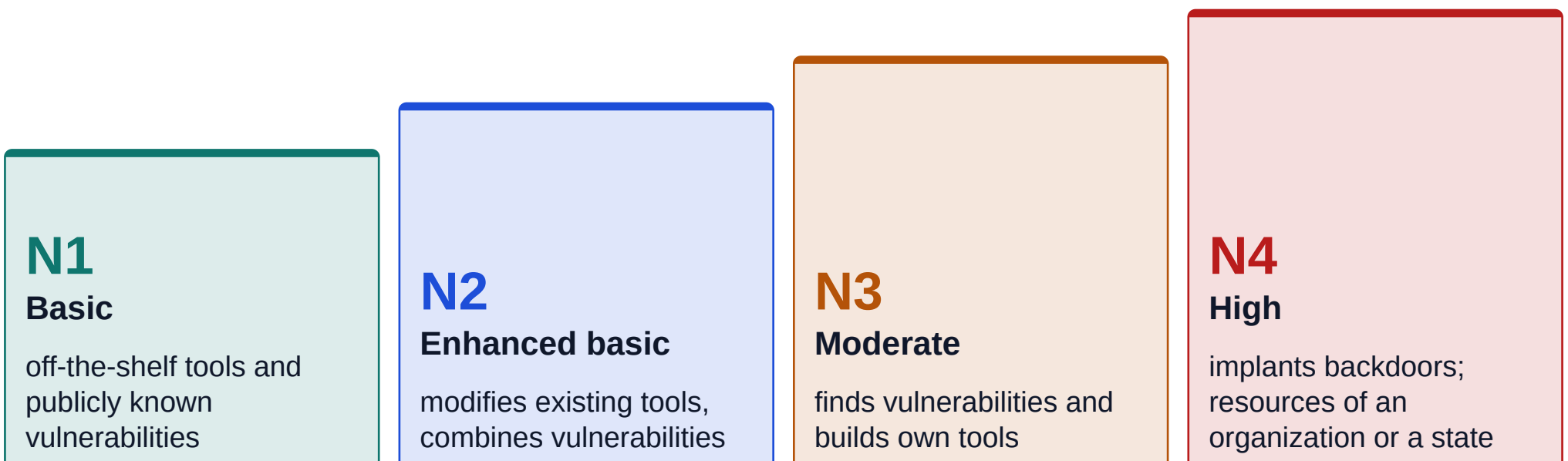
Adversary and threats

who can attack and how

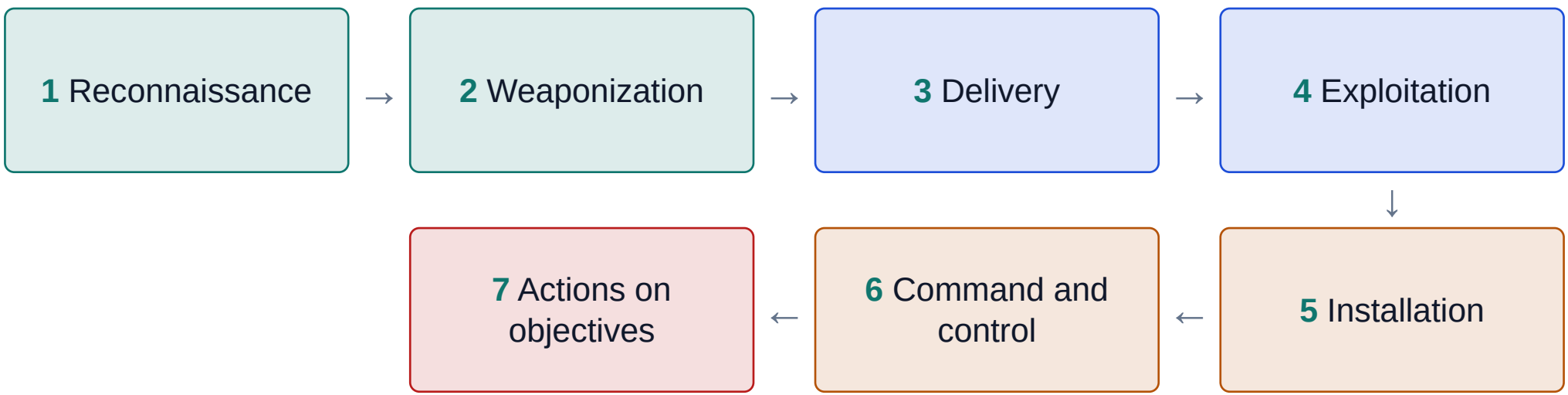
Typical adversaries

Novice curiosity; off-the-shelf tools	**Hacktivist** ideology; overload, data leaks	**Criminal group** profit; ransomware, fraud
State-sponsored group espionage; unknown vulnerabilities	**Insider** revenge, profit; data exfiltration	**Careless employee** no intent; misconfiguration

Adversary capability: N1–N4



Targeted attack chain



Attack stages and ATT&CK tactics

Stage	Tactic	Example technique	Detection
Reconnaissance	Reconnaissance (TA0043)	Active Scanning (T1595)	Web application firewall logs
Delivery	Initial Access (TA0001)	Phishing (T1566)	Mail gateway, second factor
Exploitation	Execution (TA0002)	Command and Scripting Interpreter (T1059)	Endpoint protection
Installation	Persistence (TA0003)	Scheduled Task/Job (T1053)	System audit
Command and control	Command and Control (TA0011)	Application Layer Protocol (T1071)	DNS and proxy analysis
Actions on objectives	Exfiltration (TA0010)	Exfiltration Over C2 Channel (T1041)	Data loss prevention

STRIDE: six threat types

S
Spoofing

violates authenticity

T
Tampering

violates integrity

R
Repudiation

violates non-repudiation

I
Information disclosure

violates confidentiality

D
Denial of service

violates availability

E
Elevation of privilege

violates authorization

Which threats apply to which elements

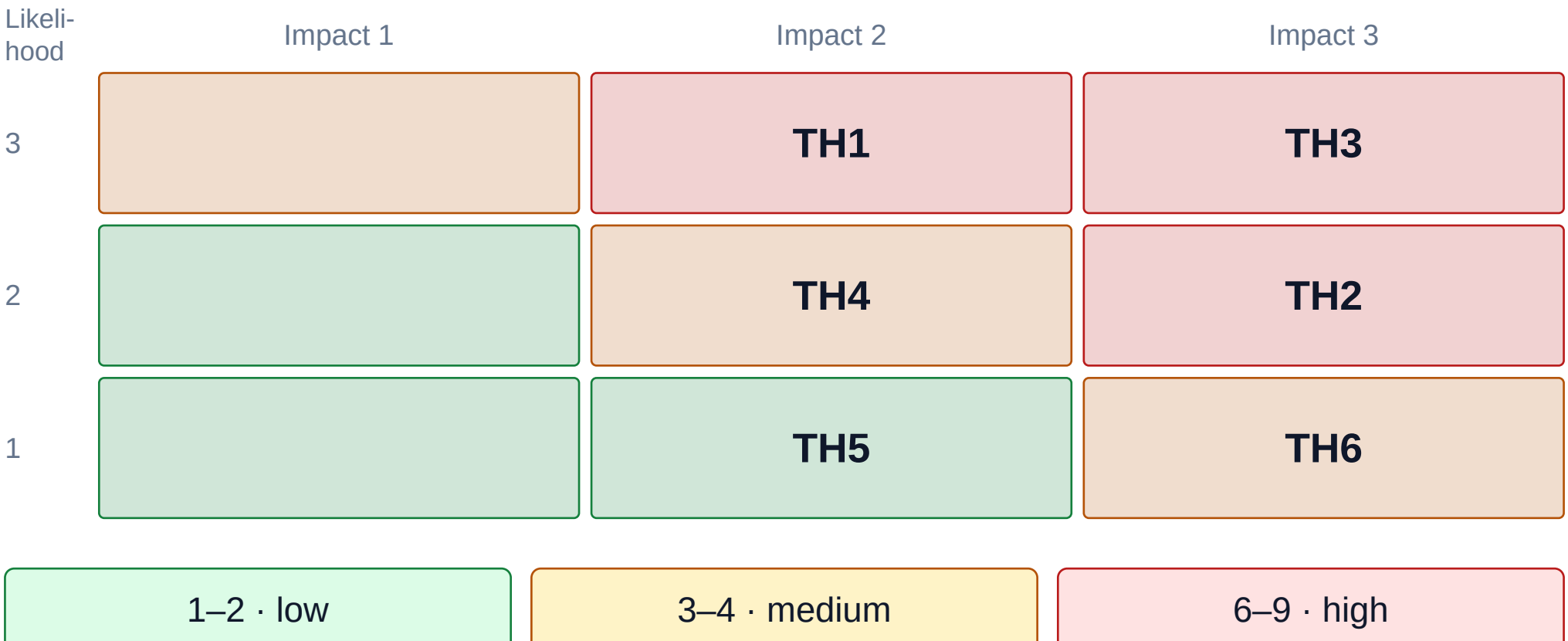
Element	S	T	R	I	D	E
External entity	✓		✓			
Process	✓	✓	✓	✓	✓	✓
Data store		✓	✓*	✓	✓	
Data flow		✓		✓	✓	

* log stores only

Threats to the web shop

No.	Element	Type	Scenario
TH1	Web application	S	Guessing a customer’s password on the login page
TH2	Database	T, I	SQL injection via the search form
TH3	Web application	I, E	Substituting someone else’s order number
TH4	Web application	D	Flood of requests to the login page
TH5	Administrator	R	Denies changing a product price
TH6	Payment request	T	Changing the amount in a request to the payment service

Risk ranking



5

Zero trust

every access is verified

Perimeter vs zero trust

Aspect	Perimeter model	Zero trust
Trust	Inside the network — trusted	Nobody is trusted by default
Verification	At network entry	Every access
Segmentation	Networks and firewalls	Fine-grained, identity-based
Lateral movement	Unrestricted	Every hop is verified
Weakness	One breach opens everything	Complexity of adoption

Seven tenets of NIST SP 800-207

1

Everything is a resource

2

All communication is secured regardless of network

3

Access is granted per session

4

Dynamic, context-based policy

5

Monitoring of device posture

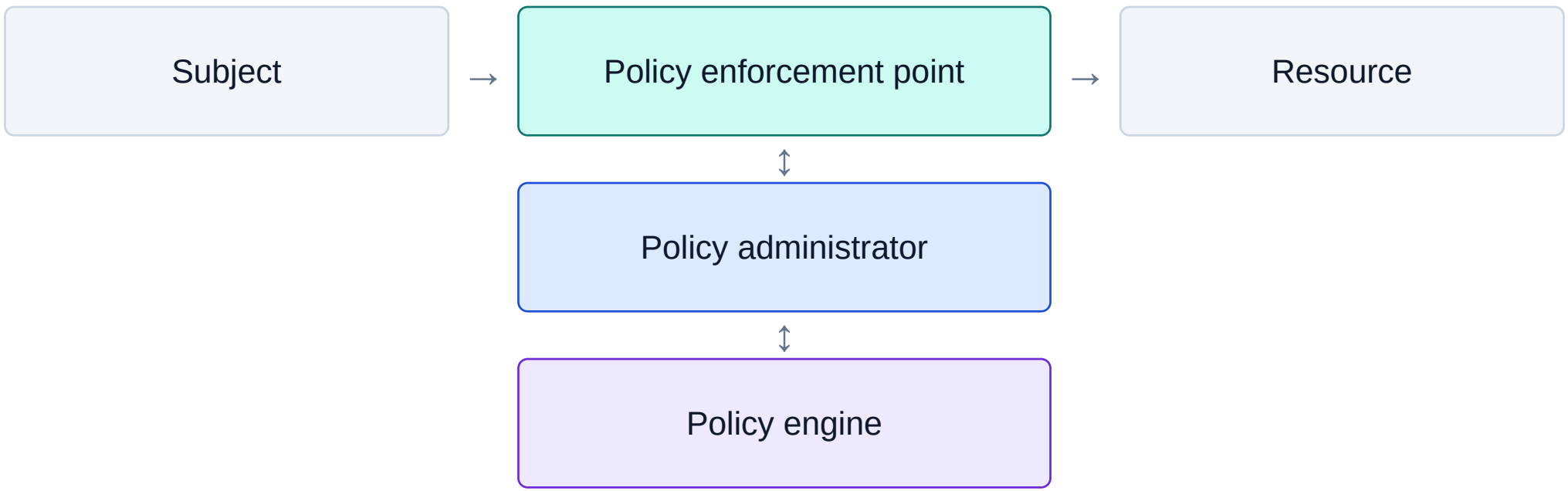
6

Verification before access, not after

7

Telemetry improves security posture

Zero trust components



The engine decides, the administrator executes, the enforcement point allows or blocks

Zero trust in the web shop

No.	Threat	How it is mitigated
TH3	Access to others' orders	Every access to an order checks the owner
TH5	Denying a price change	Second factor and logging of the action
TH2	SQL injection	The application has only the necessary database permissions
TH6	Tampering with the payment amount	The payment service accepts only signed requests

6

Security requirements

a threat becomes a verifiable requirement

Sources of requirements

Business and contracts	Industry standards	Threat modeling	Internal policies
payment data protection, service level agreements	OWASP ASVS, ISO 27001, NIST CSF, CIS Controls	a control, a test and a metric for each threat	availability, retention periods, response

OWASP ASVS 5.0

≈ 350

requirements

17

chapters

3

verification levels

Level 1	Level 2	Level 3
any application	applications with sensitive data	critical systems: healthcare, finance

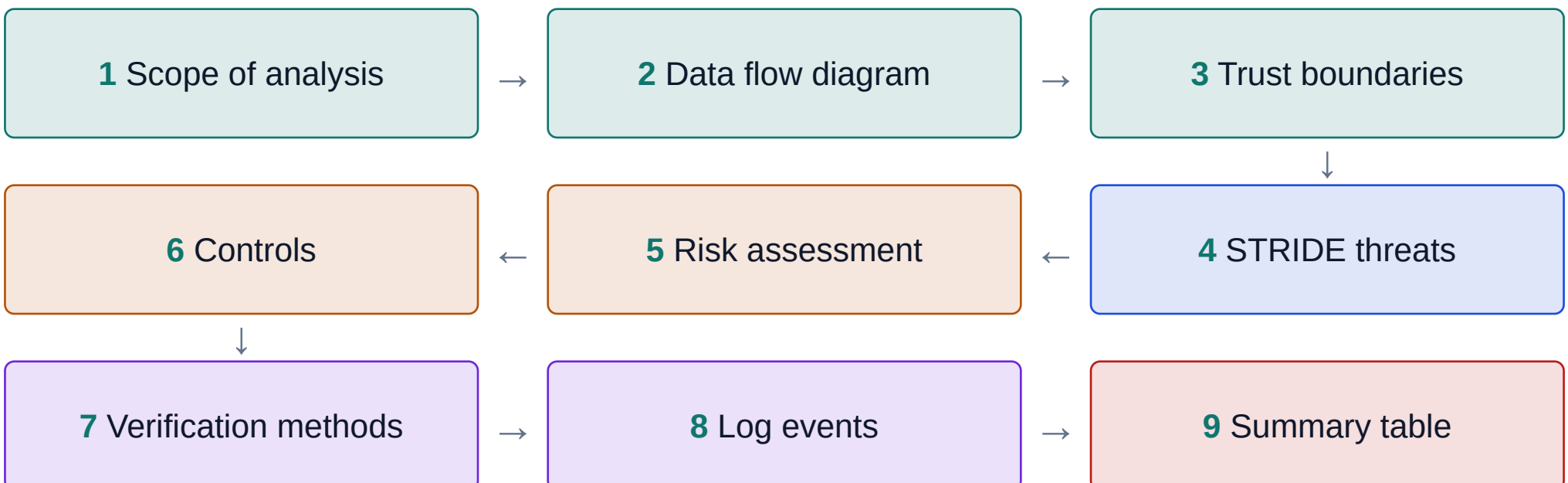
> Levels are cumulative: level 3 includes levels 1 and 2

A good security requirement

Specific	Verifiable	Traceable	Measurable
lockout after 5 failures within 15 minutes	6 wrong attempts — lockout	TH1: password guessing (S)	number of lockouts per day

Log event: auth.lockout

Nine steps of threat modeling



Summary table for the web shop

Threat	Risk	Control	Verification	Event
TH1 Password guessing	High	Second factor, rate limiting	6 attempts → lockout	`auth.lockout`
TH2 SQL injection	High	Parameterized queries, web application firewall	Static analysis, sqlmap	`waf.block.sqli`
TH3 Others' orders	High	Order ownership check	Another's order → 403	`authz.denied`
TH4 Denial of service	Medium	Rate limiting, CDN	Load test	`rate.exceeded`
TH5 Price change	Low	Tamper-evident log	Entry with author	`admin.price_change`
TH6 Payment amount	Medium	Request signing, amount reconciliation	Changed amount → rejected	`payment.mismatch`

Key points

1 Properties and principles	Three properties, eight principles, defense in depth
2 Assets and surface	Protect assets, reduce entry points
3 Trust boundaries	Verify wherever trust changes
4 Adversary and threats	Who, how, how dangerous: STRIDE and risk
5 Zero trust	Every access is verified
6 Requirements	Threat → control → verification → event

Lecture 1

Designing Secure Systems

Assets · trust boundaries · adversary · threats · requirements